

面向云数据库高敏数据暴露路径侦测的 证据约束智能体方法研究

——中期研究进展（已完成工作）

王凌云 学号：3124358181 导师：蔡忠闽

软件学院 软件工程 2026 年 7 月

1 研究背景与总体方案

云数据库已成为企业承载身份、金融、医疗等高敏数据的核心基础设施。其安全风险往往并非源自数据库引擎自身的单点缺陷，而是由公网入口、网络可达、身份权限、跨账号信任、密钥凭据、敏感数据分级与审计行为等多个维度的配置弱点相互串联、组合放大而形成的“暴露路径”(Toxic Combination, 毒性组合)。现有云安全治理工具(CSPM、CIEM、DSPM 等)多以单点扫描与列表式告警为主，难以将分散的中低危问题组织为可复核的完整路径，也难以为路径级判定提供可追溯的事实证据支撑。

大语言模型(LLM)在信息整理、任务规划与工具调用方面能力较强，为复杂云环境的自动化分析提供了新途径；但若直接以模型生成结果作为风险判定依据，则面临幻觉、知识长尾与推理不可追溯等本质挑战。为此，本课题的总体思路是：将统一风险图、工具化证据获取与确定性判定机制相结合，使 LLM 承担候选路径分析、证据查询与结果表达等“表达性”职责，而将路径合法性与风险状态的最终判定交由可复核的图约束与确定性算子完成。

本报告仅陈述截至中期**已实际完成并验证**的工作。学位论文中另行规划的图验证反馈对齐(GV-FA)等方法属于后续研究方向，其训练与验证尚在推进，故不纳入本报告的“已完成”范围。

2 已完成的主要工作

2.1 CloudDB-PathBench 评测基准的构建

面向“权限链—数据流—敏感级”三轴交叉的暴露路径评测需求，已完成评测基准的建模与生成框架，并产出可用的初步数据集。主要包括：

- **统一风险图(CDB-RG)建模**：将云环境抽象为包含身份、网络、数据库实例、数据对象、敏感标签、安全控制、审计事件与风险发现的统一风险图，以

类型化有向边刻画“可承担角色”“网络可达”“权限授予”“包含”“分类标记”等语义关系，并给出从入口条件到敏感数据目标的暴露路径形式化定义。

- **三层敏感性聚合模型**：设计“字段—表—实例”三层敏感度聚合机制，刻画敏感度沿数据层级的传递与汇聚，并给出其单调性证明。
- **参数化数据合成管线**：实现“场景来源映射—Schema 池构建—参数化合成—确定性校验”的数据构建管线，可在受控的路径长度、组合复杂度与混淆因子下批量生成结构合法的样本；已据此构造两类初步数据集：一类由多行业、多场景模板参数化合成，一类以开源云安全靶场（CloudGoat）的真实配置为种子解析映射而成。
- **数据切分与评测指标**：设计随机、未见 Schema、未见风险组合、证据损坏四种正交切分，以及覆盖路径准确性、证据完整性、排序质量与鲁棒性的多维评测指标体系。

2.2 EIC-Agent：表达—判定分离架构与确定性判定算子

提出并实现了证据完整性约束智能体方法 EIC-Agent，其核心理念是“让大语言模型从证据的判定者回归为证据的表达者”。方法将暴露路径分析组织为候选路径搜索、工具化证据获取、结构化证据表达与确定性判定四个环节：模型负责分析候选路径、调度证据查询工具并将观测整理为结构化的多维证据表达与自然语言归因；而路径是否成立、风险等级如何，则由确定性的门控—评分（Gate-Score）算子依据既定证据规则给出，模型不直接参与、亦无法改写这一判定。

该“表达—判定分离”架构使每一条风险结论都能够回溯到具体的事实证据，在利用模型语言能力的同时保证了判定的可追溯性与抗幻觉能力。围绕该架构，已对门控—评分算子的若干基本性质（如证据增加时判定的单调性、无有效证据时判定归零等）进行了形式化刻画与分析，为“判定不经过模型黑箱”提供了理论支撑。

2.3 自主证据探索与 Gate 一票否决提前终止机制

在上述架构基础上，进一步研究了智能体的探索效率问题，提出并实现了以证据状态驱动的自主探索与提前终止机制。不同于按固定顺序遍历全部证据维度的处理流程，该机制依据“代价较低、最可能否决优先”的原则对关键硬证据维度（入口、可达、权限）逐一查验，一旦某一硬性维度未达门限，即当场判定该路径证据不足并终止其后续的工具调用与模型归因，从而将“证据不足即拒绝”的安全语义前移至探索过程之中。

在基于 CloudGoat 衍生场景的实验中，该机制取得如下**实测**结果（表 1）：在不改变任何最终判定结果的前提下，约四分之一的候选路径被提前终止，相应省

去了这些路径上不必要的工具与模型调用；被终止路径的分析开销较完整流程下降约一个数量级；在证据被人为损坏的测试切分下，相关路径均被正确判定为证据不足。结果表明，将终止与剪枝决策交由确定性算子、而非模型内部的置信信号来控制，能够在保证判定正确性的同时有效提升探索效率。

表 1: 提前终止机制在 CloudGoat 衍生场景上的实测结果

指标	实测值
候选路径总数	68 条
提前终止（一票否决触发）路径数	17 条
提前终止比例	约 25%
硬证据维度实际计算比例	约 92%（在不达标维度即停）
被终止路径的分析开销	较完整流程下降约一个数量级
证据损坏切分下的判定正确率	100%（均正确判为“证据不足”）
对最终判定结果的影响	无（判定结果不变）

2.4 原型验证与可视化

为验证上述方法的工程可实现性，已将风险图构建、候选路径搜索、工具化证据获取、确定性判定与结果解释贯通为可运行的分析流程，并实现了面向分析结果的可视化展示：以图形化方式呈现风险图与候选暴露路径，按风险等级组织路径列表，并对每条路径展示其多维证据、判定依据与处置建议；对被提前终止的路径予以显式标注，对入口与目标之间不存在物理连通的场景给出明确的诊断说明，而非静默返回空结果。该验证表明所提方法在流程层面具备工程可实现性。

3 当前工作的定位与下一步计划

截至中期，本课题已完成统一风险图建模、评测基准的生成框架与初步数据集、EIC-Agent 的表达—判定分离架构与确定性判定算子，以及自主探索与提前终止机制的实现与实测试验证，形成了较为完整的方法主线与可运行的验证流程。需客观说明的是，当前工作主要面向方法验证与关键机制打通，系统性的基线对比、更大规模的数据与统计分析仍在推进之中。

下一步计划为：（1）将当前的自主探索机制扩展为完整闭环，引入基于证据状态的信息增益评估以支持动态补证与邻域扩展；（2）扩充评测基准规模并完善标注复核，在统一基准上实现规则、纯图搜索、纯模型、检索增强与无约束智能体等对照方法，开展主效果、消融与鲁棒性的系统性实验；（3）探索以图结构与证据规

则筛选训练轨迹、构造偏好样本的图验证反馈对齐方法，并据实验结果确定其实现范围；（4）完善学位论文并准备答辩。